

Lab Exercise - Lecture 1

Detect and Block SSH Brute-force Attack using Active Response

Duration: 45–60 minutes — Instructor: Hari — Phase 1

Scenario

An organisation has deployed **Wazuh** to monitor its Linux server (**Target Machine**). The Wazuh agent is installed on this server and continuously monitors system logs, including SSH authentication logs.

A separate machine running **Kali Linux** (**Attacker Machine**) is used by a security analyst to simulate real-world attacks.

One day, the analyst launches an SSH brute-force attack on the target machine using multiple username–password combinations. Wazuh is configured with:

- SSH authentication monitoring.
- Detection rules for multiple failed login attempts.
- Active Response enabled with the `firewall-drop` script.

Objective

By the end of this lab, you will:

- Launch a simulated SSH brute-force attack from the Kali Linux attacker machine.
- Observe the security alerts generated in the Wazuh Dashboard.
- Verify that Wazuh's Active Response automatically blocks the attacker's IP.
- Confirm that further SSH attempts from the attacker machine are rejected.

Prerequisites

- Wazuh Manager already deployed (provided by instructor).
- One Ubuntu 22.04 VM per student (Target Machine) with Wazuh agent installed and active.
- Kali Linux VM (Attacker Machine) on the same network as the target.
- Network connectivity between all machines and the Wazuh Manager.
- Browser access to the Wazuh Dashboard URL.

Lab Environment

Component	Details
Wazuh Manager IP	<provided by instructor>
Dashboard URL	https://<manager-ip>:443
Dashboard Username	admin
Dashboard Password	<provided by instructor>
Target Machine IP	<your assigned IP>
Attacker Machine	Kali Linux (same subnet)

Task

Perform the following steps:

1. Launch an SSH brute-force attack from the attacker machine (Kali Linux) targeting the monitored server.
2. Observe the alerts generated in Wazuh.
3. Verify that the attacker's IP is automatically blocked.
4. Confirm that further SSH attempts from the attacker machine fail.

Task 1 - Verify Active Response Configuration on the Target (10 min)

Step 1.1 - Check Active Response is enabled

On the **Target Machine**, inspect the Wazuh agent configuration:

```
sudo cat /var/ossec/etc/ossec.conf | grep -A 10 "<active-response>"
```

Listing 1: Check active response config

Ensure you can see a block referencing the **firewall-drop** command, similar to:

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5763</rules_id>
  <timeout>300</timeout>
</active-response>
```

Listing 2: Expected active-response block

Rule ID **5763** fires when Wazuh detects multiple SSH authentication failures from the same source IP (brute-force threshold). The timeout of 300 seconds means the block is lifted automatically after 5 minutes unless reconfigured.

Step 1.2 - Confirm the firewall-drop script exists

```
ls -la /var/ossec/active-response/bin/firewall-drop
```

Listing 3: Verify the active response script

The file should exist and be executable (-rwxr-x---). If it is missing, reinstall the Wazuh agent package.

Task 2 - Launch the SSH Brute-force Attack (10 min)

Perform the following steps on the **Kali Linux (Attacker Machine)**.

Step 2.1 - Install Hydra (if not already present)

```
sudo apt-get update && sudo apt-get install -y hydra
```

Listing 4: Install Hydra on Kali Linux

Step 2.2 - Create a simple wordlist

```
# Create a small username list
echo -e "root\nadmin\nuser\ntest\nubuntu" > users.txt

# Create a small password list
echo -e "password\n123456\nadmin\nletmein\nwelcome" > passwords.txt
```

Listing 5: Create username and password lists

Step 2.3 - Run the brute-force attack with Hydra

Replace <TARGET_IP> with the IP address of your Ubuntu target machine.

```
hydra -L users.txt -P passwords.txt ssh://<TARGET_IP> -t 4 -V
```

Listing 6: Launch Hydra SSH brute-force attack

The -t 4 flag limits parallel connections to 4 threads. The -V flag enables verbose output so you can watch each attempt in real time. None of the credentials will succeed - that is intentional; the goal is to generate enough failed logins to trigger the Wazuh detection rule.

You should see Hydra printing rapid [ATTEMPT] lines to the terminal. Let it run until you see at least 10–15 failed attempts, then you may stop it with **Ctrl+C**.

Task 3 - Observe Alerts in the Wazuh Dashboard (10 min)

Perform the following steps in your **browser** on the Wazuh Dashboard.

Step 3.1 - Navigate to Security Events

1. Log into the Dashboard at `https://<manager-ip>:443`.
2. In the left sidebar, click **Security Events**.
3. Filter events by your target agent name or IP.

Step 3.2 - Identify the brute-force alert

1. Look for alerts with **Rule ID 5763** (*SSHD brute-force attack*).
2. Click on one alert to expand the full event details.
3. Note the **srcip** field — this is the Kali Linux attacker IP.
4. Observe the **rule description**, **MITRE ATT&CK** tags (*T1110 – Brute Force*), and the **alert level**.

Step 3.3 - Check the Active Response log

On the **Target Machine**, inspect the active response log to confirm the block action was triggered:

```
sudo tail -f /var/ossec/logs/active-responses.log
```

Listing 7: View the active response log

You should see a line similar to:

```
Fri May 09 10:23:41 2025 /var/ossec/active-response/bin/firewall-drop  
add - <ATTACKER_IP> 1715244221.12345 5763
```

Listing 8: Expected active response log entry

The active response log should contain an entry for the attacker's IP with the action **add**, confirming that the block rule was applied. The Wazuh Dashboard should also display a **firewall-drop** Active Response event alongside the brute-force alert.

Task 4 - Verify the IP Block (10 min)

Step 4.1 - Check iptables on the Target Machine

On the **Target Machine**, verify the firewall rule was added:

```
sudo iptables -L INPUT -n --line-numbers | grep <ATTACKER_IP>
```

Listing 9: Verify iptables block rule

You should see a DROP rule for the attacker IP address.

Step 4.2 — Attempt another SSH connection from the Attacker Machine

On the **Kali Linux machine**, try a manual SSH connection to the target:

```
ssh root@<TARGET_IP>
```

Listing 10: Test SSH after block

The connection should **time out or be refused immediately**, with no password prompt appearing. This confirms that the **firewall-drop** Active Response successfully blocked the attacker IP at the network level.

Step 4.3 - Wait for the block to expire (optional)

The block is configured with a 300-second (5-minute) timeout. After this period, Wazuh will automatically remove the **iptables** rule. Verify this by re-running Step 4.1 after 5 minutes.

```
sudo iptables -L INPUT -n | grep <ATTACKER_IP>  
# Should return no output after timeout expires
```

Listing 11: Confirm rule removal after timeout

Reflection Questions

Answer these in your own words (2–3 sentences each):

- Q1.** What is the role of the **firewall-drop** Active Response script in Wazuh? How does it differ from simply generating an alert?
- Q2.** The brute-force block is set to expire after 300 seconds. In a production environment, what are the trade-offs of using a short timeout versus a permanent block? What additional mechanisms could complement Active Response?

Q3. An attacker could attempt to evade Wazuh's brute-force detection by slowing down their attack (e.g., one attempt every 30 seconds). What configuration changes in Wazuh would help detect slow brute-force attacks? Which rule or decoder would you modify?

Submission

- Screenshot of the Hydra terminal showing brute-force attempts in progress.
- Screenshot of the Wazuh Dashboard showing the **Rule ID 5763** alert with the attacker IP visible.
- Screenshot of the `active-responses.log` showing the `firewall-drop` action for the attacker IP.
- Screenshot of the `iptables` output confirming the DROP rule.
- Screenshot from the attacker machine showing the SSH connection timing out / being refused.
- Written answers to the three reflection questions.